

CONNECT IN CATALOG

Vývojářský integrační standard pro nový samostatný MCP server v systému KajovoMCPCML

SSOT - jediný závazný dokument pro připojení do katalogu

Stav dokumentu	Závazný integrační kontrakt včetně tokenového uploadu, PR/CI, podepsaného OCI runtime, autorizace, observability, vlastní HTTPS adresy a automatické aktivace po PASS.
Cílový systém	GitHub repozitář karelmartinek-a11y/KajovoMCPCML, produkční Ubuntu server, veřejná doména hcasc.cz.
Základní princip	Jedna KCML funkce = jeden samostatně působící MCP server = jedna jedinečná subdoména = právě jeden zveřejněný MCP nástroj.
Nevyjednatelné	Žádný nový MCP server nesmí být dostupný přes jinou KCML adresu, společný vícefunkční MCP endpoint ani skrytou alternativní cestu.

Verze 1.7 | 16. července 2026

1. Účel a rozsah dokumentu

Tento dokument určuje přesný postup a technické podmínky pro nový MCP server v KajovoMPCML. Pokrývá handler, vlastní HTTPS identitu, katalog, autorizaci, logging, audit, monitoring, testy a aktivaci. Verze 1.7 stanoví jediný podporovaný registrační tok: správce vystaví plně zobrazitelný integrační token se strukturovaným descriptor, programátor odešle striktní manifest a zdrojový ZIP na register.hcasc.cz a serverový job provede PR, CI, podepsaný OCI deploy, veřejné testy a automatickou aktivaci pouze po úplném PASS.

1.1 Verze katalogu a kompatibilita

Connect in Catalog v1.7 a docs/onboarding-catalogs/mcp-1.7.json tvoří jednu normativní verzi. Formát vstupního manifestu zůstává záměrně 1.5; zvýšení verze katalogu proto není změnou payloadu ani důvodem k přepisu uložených revizí.

- Strojový katalog obsahuje kanonický SHA-256 digest, úplné Draft 2020-12 schéma, programátorské OpenAPI, 35 persistovaných pipeline gateů a 11 přesných required CI checks. CI příkaz catalog:check odmítne ručně zastaralý nebo negenerovaný katalog.
- Nový intake přijímá pouze manifest schemaVersion 1.5. Již uložená schemaVersion 1.4 zůstává pouze čitelná do řízené změny nebo recertifikace; runtime ji nikdy nedoplňuje bezpečnostními defaulty.
- Kanonické nové klientské cesty jsou /v1/service-onboardings, /v1/service-onboardings/{id}, /revision a /cancel. Legacy alias /v1/onboardings zůstává pouze kompatibilní runtime cestou a nesmí být použit v nové integraci.

Dokument není obecné doporučení. Každý bod označený jako MUST, MUSÍ, NESMÍ nebo NEVYJEDNATELNÉ je release gate. Nesplnění jediného takového bodu znamená, že server nesmí být aktivován.

2. Terminologie

Pojem	Závazný význam
Správce MCP serverů	Centrální aplikace KajovoMPCML, která provozuje katalog, autorizaci, tokeny, monitoring, audit a směřování všech KCML serverů.
KCML server	Jedna samostatně působící veřejná MCP služba identifikovaná kódem KCMLxxxx a vlastní subdoménou.
KCML funkce	Jediný nástroj zveřejněný daným KCML serverem přes tools/list a volaný přes tools/call.
Handler	Interní programová implementace konkrétní funkce. Handler není veřejný endpoint a není samostatnou autorizační autoritou.
Kaja pověření	Dlouhodobé klientské pověření aplikace, agenta nebo uživatele: veřejné ID KajaXXXX a jednorázově zobrazené tajemství.
Access token	Krátkodobý Bearer token vydaný autorizačním serverem pro jediný konkrétní KCML resource.
Resource	Kanonická adresa konkrétního MCP serveru, například https://kcml0001.hcasc.cz/mcp .
Katalog	Databázový registr všech KCML serverů, jejich kontraktů, stavů, handlerů, oprávnění a provozních metrik.

3. Nevyjednatelný model izolace

MUST-ISO-01	Každý kód KCMLxxxx představuje samostatný MCP server z pohledu klienta, přestože servery fyzicky běží v jednom procesu, jedné aplikaci nebo na jednom produkčním hostiteli.
MUST-ISO-02	Server KCML0001 je dostupný pouze na https://kcml0001.hcasc.cz/mcp . Na kcml0002.hcasc.cz ani na žádné jiné adrese nesmí být jeho nástroj uveden ani volatelný.
MUST-ISO-03	Každý KCML server zveřejní přes tools/list právě jeden nástroj. tools/call s jiným názvem musí skončit chybou Invalid tool for resource.

MUST-ISO-04	Nesmí existovat veřejný společný endpoint, přes který lze volat více KCML funkcí podle parametru, kódu, názvu nebo cesty.
MUST-ISO-05	Rozlišení serveru musí být provedeno podle přesného Host headeru a záznamu hostname v katalogu. Neznámý host musí být odmítnut fail-closed odpovědí.

Klient -> <https://kcml0001.hcasc.cz/mcp> -> pouze nástroj KCML0001
 Klient -> <https://kcml0002.hcasc.cz/mcp> -> pouze nástroj KCML0002
 KCML0001 přes kcml0002.hcasc.cz -> povinně odmítnout
 Neznámá subdoména -> povinně 404, bez informací o existujících serverech

4. Aktuální architektonický základ repozitáře

Aktuální implementace používá Node.js 24, TypeScript, Fastify, PostgreSQL, React/Vite administraci a pnpm monorepo. Aplikace naslouchá interně na 127.0.0.1 a veřejné HTTPS směrování zajišťuje produkční reverse proxy.

- apps/server/src/http/mcp.ts: MCP endpoint /mcp, OAuth protected-resource metadata, Bearer kontrola, tools/list, tools/call, validace vstupu a výstupu, statistiky a audit.
- apps/server/src/domain/catalog.ts: vyhledání serveru podle přesného hostname a kanonický resource <https://<hostname>/mcp>.
- apps/server/src/domain/auth.ts: Kaja pověření, vydání krátkodobého access tokenu a ověření oprávnění.
- apps/server/src/handlers/registry.ts: registr handleru pod jednoznačným klíčem handlerKey@handlerVersion a odmítnutí duplicity.
- apps/server/src/http/admin-routes.ts: administrátorská relace, přehled serverů, generování Kaja pověření a auditní výpis.
- Aktuální protokolová verze v initialize odpovědi: 2025-11-25.

5. Povinné artefakty nového KCML serveru

Vývojář musí odeslat všechny níže uvedené vstupní artefakty v jediném validovaném manifestu a zdrojovém ZIPu. Onboarding worker z nich vytvoří auditovatelný pull request; přímé ruční založení PR ani částečná registrace bez handleru, kontraktu, testů nebo evidence nejsou podporovány intake.

Artefakt	Povinný obsah
Handler implementace	ESM modul src/index.ts exportující asynchronní function invoke(input, context); handlerKey a handlerVersion jsou závazně deklarovány v manifestu.
Vstupní JSON Schema	Striktní JSON Schema Draft 2020-12 pro argumenty nástroje; additionalProperties musí být výslovně definováno.
Výstupní JSON Schema	Striktní schéma návratové hodnoty; každá úspěšná odpověď musí projít validací.
Katalogový manifest	Vstupní manifest 1.5 obsahuje popis, handlerKey, handlerVersion, schémata, politiky, evidence a integrity digesty. Kód, hostname, resource a finální toolName přiděluje systém a vrací je v jobu; do vstupního manifestu nepatří.
Testovací vektor	Jedna nebo více konkrétních vstupních masek a očekávaných výsledků pro UI tlačítko Otestovat.
Automatické testy	Pozitivní, negativní, autorizační, izolační, schématické, chybové a logging testy.
Provozní dokumentace	Popis závislostí, timeoutu, bezpečnostních omezení, klasifikace chyb a redakce citlivých údajů.
Akceptační důkaz	Výstup CI a potvrzení všech release gates uvedených v tomto dokumentu.

6. Identita a adresování

1. Systém v transakci přidělí další nikdy nepoužité pořadové číslo a vytvoří kód KCML0001, KCML0002 atd. Po překročení čtyř číslic pokračuje bez recyklace na KCML10 000 a dále; správce ani programátor identitu ručně nevolí.
2. Hostname je odvozen pouze z kódu: kcml0001.hcasc.cz. Kód, pořadové číslo a hostname musí být navzájem konzistentní.
3. Kanonický resource je vždy `https://<hostname>/mcp`. Jiný path, alias hostname, IP adresa nebo společná doména nejsou platnou identitou serveru.
4. Kód ani hostname se po aktivaci nesmí znovu přidělit jinému serveru. Vyřazený záznam zůstává auditně zachován jako RETIRED.
5. DNS může používat wildcard záznam a reverse proxy jednu společnou upstream aplikaci. Logická izolace podle hostname však musí zůstat absolutní.

7. MCP protokolový kontrakt

7.1 Transport a endpoint

- Veřejný transport je HTTPS Streamable HTTP na cestě `/mcp`.
- Každý požadavek musí obsahovat správný Host a Authorization: Bearer `<access-token>`. Token v query stringu je zakázán.
- Aktuální implementace přijímá na `/mcp` pouze POST. Jiná metoda musí vrátit 405.
- Content type, body size, timeouty a odpovědi musí být konzistentní s centrálním serverem; lokální odchylka handleru je zakázána.

7.2 initialize

- Odpověď musí vracet aktuálně podporovanou `protocolVersion` systému, `capabilities.tools` a `serverInfo.name` rovné KCML kódu.
- `serverInfo.version` musí odpovídat `handlerVersion` z katalogu.

7.3 tools/list

- Výsledek musí obsahovat právě jeden nástroj.
- `name` musí přesně odpovídat `toolName` v katalogu; `title` odpovídá `displayName`; `description` musí jasně říkat účel, omezení a význam výsledku.
- `inputSchema` musí být stejné schéma, které je zapsáno v katalogu a použito při runtime validaci.

7.4 tools/call

- Jméno volaného nástroje musí přesně odpovídat jedinému `toolName` daného hostname.
- Vstup musí být před spuštěním handleru validován přes AJV 2020 v strict režimu.
- Výstup handleru musí být před odesláním validován proti `outputSchema`.
- Úspěšný výsledek musí obsahovat `structuredContent`. Textový obsah smí být pouze serializovanou reprezentací stejného výsledku, nikoli odlišný zdroj pravdy.
- Handler nesmí sám rozhodovat o tom, zda je token platný; autorizace probíhá před invoke v centrální vrstvě.

8. Handlerový programový kontrakt

Izolovaný handler modul:

- `src/index.ts` exportuje `async invoke(input, context)`
- `handlerKey` a `handlerVersion` jsou v manifestu 1.5
- runtime načte právě tento jediný vstup

Context:

- `correlationId`, `serverCode` a `toolName`
- `logger`: strukturovaný logger bez tajemství
- `egress.fetch`: jediná povolená řízená síťová cesta

MUST-HND-01

Handler musí být jednoznačně svázán s `handlerKey@handlerVersion`, `source commit` a ověřeným `image digestem`. Duplicitní nebo driftující vazba musí zastavit onboarding nebo runtime před invoke.

MUST-HND-02

Handler nesmí otevírat vlastní veřejný port, zavádět vlastní veřejnou cestu ani obcházet centrální `/mcp` endpoint.

MUST-HND-03	Handler nesmí přijímat nebo ukládat access token, Kaja secret, administrátorské cookies ani interní kryptografické klíče.
MUST-HND-04	Handler musí používat correlationId ve všech svých logovacích událostech a při volání navazujících systémů.
MUST-HND-05	Handler musí mít pevný timeout, řízené ukončení, klasifikované chyby a nesmí provádět nekonečné retry nebo fallback na jiný systém.
MUST-HND-06	Neznámý nebo nepodporovaný vstup musí skončit jednoznačnou chybou. Nesmí dojít k tichému doplnění, změně významu nebo provedení jiné akce.

9. Registrace do katalogu

Nový MCP server se nesmí stát dostupným pouhým přidáním handleru do kódu. Musí projít katalogovým workflow a stavovým automatem. Registrace je transakční: buď je kompletní a auditovaná, nebo server zůstává nedostupný.

1. Správce v UI vytvoří integrační token s povinným descriptoru. Ruční registrace ani přímá správcovská aktivace nového serveru nejsou dostupné.
2. Programátor odešle manifest 1.5 a bezpečný zdrojový ZIP přes multipart POST /v1/service-onboardings s Bearer tokenem a stabilním Idempotency-Key.
3. Intake striktně ověří manifest, JSON Schema, sémantické invarianty, evidence a ZIP ještě před transakční rezervací KCML kódu, hostname, resource a finálního toolName.
4. Onboarding worker vytvoří omezený PR pouze pod handlers/KCMLNNNN, vyžádá všech 11 CI checků a ukládá výsledek každého gate samostatně.
5. Po PASS worker ověří source commit, podepsaný immutable OCI image, SBOM a provenance a spustí handler v izolovaném rootless Podman workeru.
6. Preflight ověří DNS, TLS SAN, Host routing a worker readiness; trial použije skutečný OAuth/MCP tok, safeInput, schémata, audit, redakci a monitoring.
7. Pouze úplný PASS všech 35 persistovaných gateů přepne server automaticky přes REGISTERED_DISABLED a TRIAL_TESTING do ACTIVE/enabled=true.
8. Opravitelný stav AWAITING_REVISION nebo FAILED vyžaduje celý nový manifest a ZIP přes PUT /v1/service-onboardings/{id}/revision, nový Idempotency-Key a aktuální If-Match.
9. QUARANTINED a CANCELLED se nesmějí obejít. Jakékoli následné vypnutí aktivního serveru zvýší revokační epochu a působí okamžitě i na dříve vydané tokeny.

10. Povinné UI pro integraci a správu

Každý údaj potřebný pro registraci, autorizaci, oprávnění, testování, monitoring a provozní správu musí být dostupný v administrátorském UI. Vývojář nesmí požadovat, aby správce kvůli novému KCML serveru ručně upravoval .env, INI, YAML, JSON, databázi, reverse proxy, systemd jednotku nebo zdrojový kód.

Obrazovka / část UI	Povinné funkce
Katalog serverů	Kód, označení, plná HTTPS adresa, stav registrace, provozní stav, zapnuto/vypnuto, verze handleru, verze kontraktu.
Detail serveru	Popis, toolName, vstupní a výstupní maska, handler, digesty, stavový automat, oprávnění, statistiky a audit.
Registrace	Vystavení integračního tokenu a descriptoru, stažení katalogu v1.7 a dohled nad automatickým jobem, gate výsledky a opravnými revizemi.
Kontrakty	Čitelný náhled aktivní revize, input/output schémat, digestů a politik; změna kontraktu probíhá pouze novou auditovanou onboarding revizí.
Testování	Tlačítko Otestovat, editace testovacího vstupu, zobrazení přesné odpovědi, latence, schématické validace a klasifikace chyby.

Obrazovka / část UI	Povinné funkce
Provozní přepínač	Zapnout/vypnout s potvrzením; vypnutí účinkuje okamžitě i pro platné tokeny.
Tokeny a Kaja pověření	Generování, jednorázové zobrazení secretu, popis, platnost, aktivace, revokace, smazání a oprávnění ke KCML serverům.
Oprávnění	Přidání nebo odebrání jednotlivých KCML serverů ke konkrétnímu Kaja pověření; žádné implicitní globální oprávnění.
Monitoring	Počty úspěšných, chybných a neautorizovaných volání, poslední úspěch, poslední chyba, latence a zdravotní stav.
Audit	Filtrovatelné události podle času, kódu, Kaja ID, typu události, výsledku a correlationId.
Konfigurace integrace	Měnitelné provozní parametry i secret reference spravuje typed DB registr. Secret hodnoty jsou v DB envelope-AEAD šifrované a API je nikdy nevrací; bootstrap master klíče zůstávají mimo DB v oddělených systemd credentials.
Diagnostika	Kontrola DNS, TLS, dostupnosti handleru, databáze, autorizačního serveru a přesné routovací izolace.

11. Autorizace a tokenizace

11.1 Kaja pověření

- Každý agent, program nebo uživatel má vlastní Kaja pověření. Sdílení jednoho pověření mezi nezávislými klienty je zakázáno.
- Veřejné ID má konvenci Kaja0001, Kaja0002 atd. Číslo se nikdy nerecyklují; po Kaja9999 následuje Kaja10 000.
- Tajný client secret je kryptograficky náhodný, zobrazí se pouze jednou a v databázi je pouze bezpečný hash a fingerprint.
- Po vytvoření nelze secret ani původní platnost měnit. Lze změnit popis a oprávnění, pověření zneplatnit nebo smazat.
- Smazané ID nesmí být znovu použito.

11.2 Oprávnění

- Oprávnění je explicitní vazba Kaja pověření -> konkrétní KCML server.
- Jedno pověření může mít více KCML serverů; jeden KCML server může být povolen více pověřeními.
- Bez explicitní aktivní vazby se access token pro daný resource nevydává.
- Odebrání oprávnění musí okamžitě zablokovat vydání nových tokenů a revokovat účinek stávajících tokenů přes revocation epoch nebo ekvivalentní mechanismus.

11.3 Vydání access tokenu

- Klient použije client_credentials vůči https://auth.hcasc.cz/oauth/token a pošle přesný resource cílového KCML serveru.
- Autorizační server ověří Kaja ID, secret, aktivní stav, expiraci, oprávnění, enabled stav serveru a registrační stav ACTIVE nebo TRIAL.
- Vydaný access token je krátkodobý, opaque a navázaný na schválený přístup konkrétního MCP serveru.
- Bearer token musí být poslán v Authorization headeru při každém HTTP požadavku.
- Chybějící nebo neplatný token: HTTP 401. Platný klient bez oprávnění: HTTP 403 při token flow. Vypnutý server: HTTP 503.

11.4 MCP autorizační metadata

- Každý KCML hostname musí poskytovat OAuth Protected Resource Metadata na root well-known URI a na cestě odpovídající /mcp.
- Metadata musí uvádět přesný resource a centrální authorization_servers hodnotu https://auth.hcasc.cz.
- 401 odpovědi obsahují standardní WWW-Authenticate Bearer challenge s odkazem resource_metadata na metadata přesného MCP resource a s požadovaným scope.

12. Monitoring

Monitoring musí být provozní, ne pouze dekorativní. Každý údaj musí být odvozen ze skutečných událostí a perzistentních statistik. Po restartu se kumulativní počty nesmí vynulovat.

Metrika	Přesná interpretace
Celkový počet úspěšných volání	Zvýší se pouze po úspěšném handleru a úspěšné validaci výstupu.
Celkový počet neúspěšných autorizovaných volání	Chyba handleru, timeout, upstream chyba nebo neplatný výstup.
Celkový počet neautorizovaných volání	Chybějící, neplatný nebo expirovaný Bearer token.
Poslední úspěšné volání	UTC datum a čas dokončeného úspěchu.
Poslední neúspěšné volání	UTC datum a čas poslední autorizované chyby.
Poslední neautorizované volání	UTC datum a čas posledního odmítnutého přístupu.
Latence	Alespoň poslední hodnota, průměr a p95 za definované období.
Provozní stav	UNKNOWN, DISABLED, HEALTHY, DEGRADED, UNHEALTHY, QUARANTINED, MAINTENANCE nebo RETIRED.
Dostupnost handleru	Zda je schválený handlerKey@handlerVersion svázán s ověřeným image digestem a zda je jeho izolovaný runtime worker připraven.
Stav kontraktu	Zda jsou schémata platná a digesty odpovídají schválenému artefaktu.

13. Standard loggingu a auditu

MUST-LOG-01	Všechny logy jsou strukturované. Volný text bez povinných polí nesmí být jediným záznamem události.
MUST-LOG-02	Každé volání dostane correlationId při vstupu do MCP vrstvy. Stejně ID se používá v autorizaci, auditu, handleru, upstream voláních i výsledku diagnostiky.
MUST-LOG-03	Nikdy se neloguje client secret, access token, session cookie, CSRF token, TOTP secret, heslo, šifrovací klíč ani plná citlivá payload data.
MUST-LOG-04	Pro identifikaci pověření se používá interní credentialId, veřejné Kaja ID nebo bezpečný fingerprint, nikoli tajná hodnota.
MUST-LOG-05	Každá chyba musí mít stabilní errorCode a classification; samotná message nestačí.
MUST-LOG-06	Auditní události jsou append-only. Vývojář handleru je nesmí mazat, přepisovat ani obcházet.

Povinná pole záznamu podle relevance:

- timestamp UTC
- level
- eventType
- correlationId
- KCML code
- hostname/resource
- toolName
- handlerKey
- handlerVersion
- credentialId nebo fingerprint
- result
- HTTP status
- JSON-RPC error code
- latencyMs
- errorCode

- classification
- upstream system
- buildId

Minimální povinné typy událostí:

mcp.request.received, mcp.unknown_host, mcp.disabled, mcp.unauthorized, mcp.invocation.accepted, mcp.invocation.completed, mcp.invocation.failed, mcp.input_schema_failed, mcp.output_schema_failed, mcp.handler_unavailable, mcp.timeout, mcp.upstream_failed, access_token.issued, access_token.denied, permission.granted, permission.revoked, server.registered, server.enabled, server.disabled, server.test.started, server.test.completed, server.test.failed, server.quarantined

14. Chybový kontrakt

Situace	Povinná reakce
Neznámý hostname	HTTP 404; bez seznamu platných hostů a bez detailu katalogu.
Nesprávná HTTP metoda	HTTP 405.
Chybějící nebo neplatný Bearer	HTTP 401; audit mcp.unauthorized.
Server vypnutý nebo neaktivní	HTTP 503; žádné spuštění handleru.
Nesprávný toolName	JSON-RPC –32 602 Invalid tool for resource.
Neznámá MCP metoda	JSON-RPC –32 601 Method not found.
Neplatný vstup	JSON-RPC –32 602 Input schema validation failed.
Handler není v buildu	HTTP 503 handler_unavailable.
Chyba handleru nebo výstupu	JSON-RPC –32 603 Handler failed; interní detail pouze do bezpečného logu.
Timeout	Řízená chyba s classification=timeout; žádný nekonečný běh a žádný fallback.

15. Testovací standard

Nový KCML server nesmí být zařazen do TRIAL ani ACTIVE bez automatických testů níže. Tlačítko Otestovat v UI nenahrazuje CI testy; je provozní diagnostikou nad již schváleným kontraktem.

Test	Akceptační podmínka
T-01 Inicializace	initialize vrátí správný KCML code a handlerVersion.
T-02 Jediný nástroj	tools/list vrátí právě jeden nástroj a správné inputSchema.
T-03 Správná funkce	tools/call správného názvu a platného vstupu dokončí handler a validuje výstup.
T-04 Cizí funkce	Nástroj z jiného KCML serveru je na tomto hostname odmítnut.
T-05 Křížová subdoména	Token i nástroj KCML0001 jsou na kcml0002.hcasc.cz odmítnuty.
T-06 Bez tokenu	Požadavek bez Bearer tokenu je odmítnut před handlerem.
T-07 Neplatný token	Chybný, expirovaný nebo pro jiné audience/resource vydaný token je odmítnut před handlerem.
T-08 Oprávnění	Kaja bez vazby na server nezíská access token.
T-09 Vypnutí	Po enabled=false nefunguje ani dříve platný token.
T-10 Vstupní schéma	Chybějící, nadbytečné a typově chybné hodnoty jsou odmítnuty.
T-11 Výstupní schéma	Neplatný výstup handleru je chyba a nezvýší success_count.

Test	Akceptační podmínka
T-12 Timeout	Překročení limitu je ukončeno a auditováno.
T-13 Logging redaction	V logu ani auditu není secret ani access token.
T-14 Statistika	Úspěch, chyba a neautorizované volání aktualizují správné oddělené metriky.
T-15 Restart	Po restartu zůstává katalog, oprávnění i kumulativní statistika zachována.
T-16 UI test	Test z UI používá skutečný MCP tok, nikoli přímé volání handleru obcházející autorizaci a validaci.

16. Produkční routing a provoz na společném serveru

- Centrální web, autorizace a katalog mohou obsluhovat více KCML identit na jednom produkčním serveru. Každý onboardovaný handler však běží ve vlastním rootless Podman workeru; samostatnost je protokolová, autorizační, katalogová i runtime-isolační.
- Reverse proxy musí předávat původní Host a TLS musí pokrývat příslušné subdomény, například wildcard certifikátem pro *.hcasc.cz.
- Veřejné subdomény směřují do stejného interního upstreamu; upstream vybere záznam výhradně podle hostu.
- Žádný nový KCML server nesmí vyžadovat nový veřejný port. Ochrana proti konfliktům s jinými aplikacemi spočívá v centrálním reverse proxy routingu a interním bindu aplikace na 127.0.0.1.
- Registrace nové subdomény, kontrola DNS, TLS a routing musí být automatizována nebo provedena z UI správce; běžná správa nesmí vyžadovat ruční editaci proxy konfigurace.
- Neznámá, neregistrovaná nebo vyřazená subdoména nesmí být automaticky přesměrována na existující MCP server.

17. Zákaz fallbacků a skrytých cest

NO-FALLBACK-01	Pokud handler, upstream systém, kontrakt, oprávnění nebo konfigurace nejsou dostupné, volání musí skončit přesnou chybou. Nesmí být použita náhradní funkce.
NO-FALLBACK-02	Nesmí existovat fallback z konkrétní subdomény na obecný katalog nebo jiný KCML server.
NO-FALLBACK-03	Nesmí existovat anonymní režim, implicitní oprávnění, master token pro běžné klienty ani bypass pro interní volání ze stejného serveru.
NO-FALLBACK-04	Interní a externí klient se stejným platným tokenem a oprávněním mají stejné autorizační chování. Umístění klienta nesmí změnit oprávnění.
NO-FALLBACK-05	Žádná konfigurace nového MCP serveru nesmí být skrytě doplněna z .env nebo lokálního souboru, pokud má být spravována administrátorem.

18. Povinný vývojářský checklist před předáním

- ☐ KCML kód a hostname byly přiděleny systémem a nebyly ručně zvoleny.
- ☐ Hostname je jedinečný a resource přesně odpovídá https://hostname/mcp.
- ☐ tools/list vrací právě jeden nástroj.
- ☐ Jiný nástroj není na tomto serveru volatelný.
- ☐ Handler je registrován pod jedinečným handlerKey@handlerVersion.
- ☐ Vstupní i výstupní schéma jsou striktní a testovaná.
- ☐ Handler neobsahuje vlastní autorizaci ani veřejný endpoint.
- ☐ Access token je krátkodobý, opaque a vydaný pouze po splnění schválených autorizačních podmínek.
- ☐ Bez oprávnění nelze token vydat.

- ☐ Vypnutí serveru okamžitě blokuje provoz.
- ☐ UI obsahuje registraci, kontrakty, test, oprávnění, monitoring a audit.
- ☐ Veškeré administrovatelné nastavení je dostupné v UI.
- ☐ Logy obsahují correlationId a neobsahují tajemství.
- ☐ Byly provedeny požadované provozní a bezpečnostní testy integračního postupu.
- ☐ Byly provedeny timeout a schema-failure testy.
- ☐ CI příkaz pnpm run ci prošel bez chyby.
- ☐ Produkční preflight ověřil DNS, TLS, databázi, handler a fail-closed routing.
- ☐ Server byl aktivován pouze automatickým stavovým automatem po úplném PASS; při automatickém onboardingu není závěrečné ruční kliknutí ani možnost obejít gate.

19. Akceptační definice „Connect in Catalog“

Nový MCP server je považován za úspěšně připojený do katalogu pouze tehdy, když současně platí všechny následující podmínky:

- Je evidován v katalogu pod jedinečným KCML kódem, hostname a resource.
- Na svém hostname zveřejňuje právě jeden správný nástroj a žádný jiný.
- Na žádném jiném hostname není tento nástroj dostupný.
- Platný access token musí být vydán výhradně pro jeho resource a musí být podmíněn explicitním oprávněním Kaja pověření.
- Handler, vstupní i výstupní kontrakt a testovací vektory odpovídají schváleným verzím a digestům.
- Monitoring, statistiky, audit a strukturované logy vykazují skutečný provoz daného serveru.
- Veškerá administrace probíhá přes UI bez ruční konfigurace provozních souborů.
- Všechny testy a release gates tohoto dokumentu jsou splněny bez fallbacků, výjimek nebo skrytých bypassů.

20. Ověřený stav vykonávaného repozitáře

Následující body byly ověřeny proti vykonávanému zdrojovému kódu, migracím a automatizovaným testům při vydání katalogu v1.7. Nejsou náhradou runtime gateů; vymezují centrální schopnosti, které nový handler používá a nesmí duplikovat ani obcházet.

Zjištění	Ověřený provozní důsledek
Jádro izolace již existuje	MCP server se vyhledává podle přesného hostname, tools/list vrací jeden nástroj a tools/call odmítá jiné jméno.
Vydávání access tokenů již existuje	Access token je v databázi veden jako krátkodobý autorizační artefakt a validace kontroluje jeho stav a oprávnění.
Oprávnění již existuje v backendu	Vydání access tokenu kontroluje aktivní vazbu kaja_permission mezi credential a serverem.
Centrální monitoring je úplný a oddělený	Centrální monitor ukládá per-probe vzorky, staleness, SLO, stavovou historii, aktivní alerty a webhook delivery; metriky úspěchu, autorizovaných chyb i odmítnutých volání jsou persistentní.
Administrátorské UI pokrývá celý provozní životní cyklus	UI zobrazuje katalog, tokeny, descriptor, oprávnění, registrační revize, recertifikaci, testování, monitor, alerty, webhook delivery, audit a řízené změnové operace.
Konfigurace je rozdělena na bootstrap a typed DB registr	Process env slouží jen pro bootstrap DB, vaultu a role procesu. Měnitelná konfigurace je verzovaná, auditovaná a spravovaná přes UI; secret hodnoty jsou envelope-AEAD šifrované a API je nevrací.
OAuth metadata jsou základní	Protected Resource Metadata i standardní WWW-Authenticate Bearer challenge jsou implementovány centrálně; klient se řídí metadata URL a přesným resource/scope bez handlerové odchylky.
Referenční handler a obecný registr jsou součástí vykonávaného kódu	KCML0002 poskytuje referenční izolovaný handler a kontraktní testy; nový handler musí zachovat obecné rozhraní registru bez doménových větví v MCP jádře.

21. Zdrojové opory

Repozitářové soubory použité pro forenzní ověření:

- package.json
- apps/server/src/index.ts
- apps/server/src/app.ts
- apps/server/src/http/mcp.ts
- apps/server/src/http/auth-routes.ts
- apps/server/src/http/admin-routes.ts
- apps/server/src/domain/catalog.ts
- apps/server/src/domain/auth.ts
- apps/server/src/domain/types.ts, onboarding.ts, registration.ts, mcp-policy.ts a server-state.ts
- apps/server/src/handlers/registry.ts

Normativní protokolové zdroje: Model Context Protocol Specification 2025-11-25 - Authorization, Transports a Tools. Při budoucí změně protokolové verze musí být provedena řízená aktualizace centrálního systému i tohoto integračního kontraktu; jednotlivý handler nesmí jednostranně změnit protokol.

22. Závaznost

Release gate	Implementace nového KCML serveru, která nesplní kterýkoli nevyjednatelný bod tohoto dokumentu, nesmí být sloučena, zaregistrována, povolena ani nasazena do produkce.
--------------	---

23. Povinný generativní protokol

Tato kapitola se použije pokaždé, když je tento dokument přiložen k zadání člověku, AI generátoru nebo automatizovanému vývojovému nástroji. Přiložení dokumentu samo o sobě není důkazem shody. Důkazem je až úplná matice požadavků, úspěšné automatické testy, akceptační balíček a produkční preflight.

MUST-GEN-00	Generátor musí považovat tento dokument za normativní vstup s vyšší prioritou než neformální pokyny. Nesmí vyhlásit dokončení, pokud je jediný povinný bod ve stavu FAIL, BLOCKED nebo NOT TESTED.
-------------	--

23.1 Povinný vstupní balíček

Před zahájením implementace musí zadavatel nebo katalogový systém zpřístupnit následující údaje. Generátor je nesmí odhadovat, doplňovat z příkladů ani nahrazovat pohodlnějším výchozím nastavením.

- Funkční zadání jediného nástroje: účel, povolené vstupy, očekávaný výstup, omezení a zakázané vedlejší účinky.
- Systémem přidělená identita: KCML kód, přesný hostname a kanonický resource ve tvaru `https://<hostname>/mcp`.
- `toolName`, `displayName`, `handlerKey`, `handlerVersion` a `registrationRevision`, nebo oprávnění tyto hodnoty navrhnout ke schválení.
- Schválená `inputSchema` a `outputSchema`, případně dostatečné doménové zadání k jejich vytvoření a následnému lidskému schválení.
- Timeout, očekávané upstream systémy, klasifikace chyb, citlivost dat, retenční omezení a pravidla redakce.
- Cílový repozitář, větev nebo pracovní kopie a aktuální příkaz CI; implementace musí vycházet ze skutečného stavu repozitáře.

MUST-GEN-01	Před prvním uploadem musí zdroj zůstat bez natvrdo zvolené KCML identity. UNASSIGNED balík je registrovatelný pouze přes programátorské API; kód, hostname, resource a finální <code>toolName</code> smí doplnit výhradně transakční onboardingový job.
-------------	---

23.2 Závazný postup od zadání po aktivaci

1. Načíst celý tento dokument a prozkoumat aktuální repozitář, jeho `AGENTS.md`, build, datový model, centrální MCP vrstvu, registr handlerů, autorizační vrstvu, UI, testy a provozní konvence. Před touto inventurou neprovádět změny kódu.
2. Vytvořit matici shody ve formátu požadavek -> implementační artefakt -> automatický test -> důkaz -> stav. Zahrnout všechny identifikátory MUST, NO-FALLBACK, T-01 až T-25 a všechny věty označené MUSÍ, NESMÍ nebo NEVYJEDNATELNÉ.
3. Použít integrační token a POST `https://register.hcasc.cz/v1/service-onboardings`. Identitu rezervuje transakčně systém; programátor převezme přidělený KCML kód, hostname, resource a `toolName` beze změny. Identitu nevkládá do vstupního manifestu ani natvrdo do handleru.
4. Navrhnout a schválit jediný `toolName`, popis, `inputSchema`, `outputSchema`, `registrationRevision` a testovací vektory. Schémata musí být Draft 2020-12, striktní a použita shodně v katalogu, runtime validaci i testech.
5. Implementovat Node.js 24/TypeScript handler s exportovanou async function `invoke` a automatickými testy. Zdroj odeslat jako bezpečný ZIP; nevytvářet vlastní veřejný port, cestu, MCP server, tokenovou validaci, Dockerfile ani alternativní vstup do funkce.
6. Připravit konfigurační kontrakt. Administrátorem měnitelné hodnoty musí být spravovatelné v UI; tajemství musí být uložena šifrovaně, po uložení nezobrazitelná a do handleru předána pouze v minimálním nezbytném rozsahu. Do repozitáře patří jen bezpečné placeholder.
7. Odevzdat handler centrálnímu onboardingovému toku; katalog, MCP endpoint, identity a stavový automat propojuje výhradně platforma. Přesný Host musí vybrat právě jeden katalogový záznam a neznámý, neaktivní nebo vyřazený host skončí fail-closed bez spuštění handleru.
8. Ověřit centrální autorizační hranici: resource metadata, vydání tokenu přes `client_credentials`, explicitní Kaja oprávnění, expiraci, revokaci, enabled stav a odmítnutí neplatného tokenu před `invoke`.
9. Doplnit strukturované logy, append-only audit, `correlationId`, klasifikované chyby, redakci tajemství a perzistentní metriky úspěchu, autorizované chyby, neautorizovaného volání, latence a provozního stavu.
10. Spustit pozitivní, negativní, schématické, autorizační, izolační, timeoutové, redakční, restartové a provozní testy T-01 až T-25 a úplný příkaz `pnpm run ci`. Každý neúspěch opravit nebo označit BLOCKED; test nesmí být přeskočen bez schválené změny standardu.
11. Nechat onboardingový job po podpisové kontrole a izolovaném deployi vytvořit katalogový záznam `REGISTERED_DISABLED/enabled=false`, monitoring profile, statistiky, auditní vazby a digesty. Programátor stav ani databázi ručně nemění.

12. Onboardingový job provede produkční preflight nad přidělenou HTTPS adresou, přejde do TRIAL_TESTING, vytvoří omezené systémové Kaja pověření a provede OAuth/MCP/logging/audit/monitoring testy. Po úplném PASS automaticky přejde do ACTIVE/enabled=true bez závěrečného kliknutí; jinak server vypne nebo karanténuje.

23.3 Povinné stop podmínky

Situace	Povinný výsledek
Identita před prvním uploadem ještě není přidělena	Připravit validní manifest 1.5 a ZIP bez vymyšlené adresy a odeslat je přes token-bound POST. Stav BLOCKED vzniká až při chybějícím zadání, tokenu nebo schválení, nikoli pouhou absencí dosud nepřiděleného KCML kódu.
Zadání odporuje tomuto dokumentu	Použít přísnější pravidlo. Pokud by výsledek změnil architekturu nebo bezpečnostní hranici, zastavit práci a vyžádat rozhodnutí správce.
Chybí schéma, testovací vektor nebo akceptační podmínka	Neimplementovat domněnku jako produkční chování; označit BLOCKED a vyžádat doplnění nebo schválení návrhu.
Selže povinný test nebo CI	Server zůstává disabled. Zákaz ručního přepnutí výsledku, zakázání testu nebo výjimky bez změny standardu.
Centrální UI neumí spravovat povinnou konfiguraci	Doplnit centrální schopnost nebo integraci zablokovat. Zakázán skrytý .env, lokální soubor nebo ruční databázový zásah.
DNS, TLS, autorizace, databáze nebo routing nejsou ověřitelné	Žádná aktivace. Stav BLOCKED nebo QUARANTINED podle fáze životního cyklu.

24. Akceptační balíček a strojové release gates

Každá generovaná implementace musí spolu s kódem dodat auditovatelný akceptační balíček. Důkazy musí být svázány s konkrétním buildId, handlerVersion, registrationRevision a digesty schémat; nesmí být převzaty z jiného serveru ani staršího buildu.

24.1 Povinné důkazy

ID	Důkaz	Minimální obsah
C-01	Identita	Export katalogového záznamu s přiděleným KCML kódem, hostname a přesným HTTPS resource.
C-02	Handler a registr	Cesty změněných souborů, handlerKey@handlerVersion a důkaz odmítnutí duplicity.
C-03	Kontrakt	inputSchema, outputSchema, registrationRevision, testovací vektory a kryptografické digesty.
C-04	Autorizace	Výsledky vydání tokenu, chybějícího oprávnění, expirace, revokace a disabled stavu.
C-05	Izolace	Důkaz jednoho nástroje a odmítnutí neznámého hostu.
C-06	Observabilita	Ukázkové strukturované události bez tajemství, auditní záznamy a změny perzistentních metrik.
C-07	Tajemství	Výsledek secret scan a redakčního testu; potvrzení, že klientský bundle, logy a fixture neobsahují tajné hodnoty.
C-08	CI	Příkaz, čas, commit/buildId a úplný úspěšný výstup pnpm run ci bez přeskočených povinných testů.
C-09	Preflight	DNS, TLS, HTTPS, metadata, routing, auth, databáze, handler, fail-closed a post-deploy smoke test.
C-10	Finální stav	Úplná matice shody se stavem PASS u každého povinného bodu a identitou schvalující osoby nebo workflow.

24.2 Rozšířené automatické testy

Test	Akceptační podmínka
T-17 Přidělená identita	Manifest, katalog, initialize a runtime context používají tentýž systémem přidělený KCML kód, hostname a resource.
T-18 HTTPS a routing	Přidělený hostname má platný TLS řetězec, zachovává Host a nesměruje na alias, IP ani společný vícefunkční endpoint.
T-19 OAuth metadata	Protected Resource Metadata uvádějí přesný resource a centrální authorization server; challenge odpovídá aktuálnímu centrálnímu profilu.
T-20 JSON-RPC a transport	Parser rozliší parse error, invalid request, method, params a internal error; odmítne chybný Content-Type/Accept a notifikace nevrací tělo.
T-21 Revokace a vypnutí	Odebrání oprávnění i enabled=false zablokuje nové tokeny a účinek dříve vydaných tokenů podle centrální revokační politiky.
T-22 Korelace a persistence	Jedno correlationId propojuje request, auth, audit, handler a výsledek; metriky přežijí restart a mají správně oddělené čítače.
T-23 Secret scan	Repozitář, build artefakty, klientský bundle, logy, audit a testovací fixture neobsahují client secret, access token ani jiné zakázané tajemství.
T-24 Integrita artefaktů	Digesty schémat a manifestu odpovídají runtime artefaktům; změna bez nové verze nebo schválení je odmítnuta.
T-25 Úplnost důkazů	Akceptační balíček C-01 až C-10 je úplný, svázaný s jedním buildId a nemá povinný stav FAIL, BLOCKED ani NOT TESTED.

24.3 Povolené stavy matice shody

- PASS - implementace i automatický důkaz splňují požadavek v tomto konkrétním buildu.
- FAIL - důkaz prokazuje nesplnění; release je zakázán.
- BLOCKED - důkaz nelze získat nebo chybí rozhodnutí; release je zakázán.
- NOT TESTED - kontrola nebyla provedena; u povinného bodu je release zakázán.
- NOT APPLICABLE - lze použít jen tehdy, když požadavek výslovně připouští neaplikovatelnost a správce uvede písemné odůvodnění. Nelze jím obejít MUST nebo NESMÍ.

MUST-GEN-02

Souhrnný stav je PASS pouze tehdy, když je každý povinný řádek PASS. Agregace nesmí skrýt jednotlivé selhání procentem úspěšností, průměrem ani manuálním přepsáním výsledku.

25. Povinná instrukce při použití dokumentu jako přílohy

Následující text se přikládá k funkčnímu zadání beze změny. Zadavatel doplní pouze specifikaci funkce a systémem přidělenou identitu. Text je určen pro AI generátor, vývojáře i automatizovaný scaffolding nástroj.

ÚKOL: Připrav nový samostatný KCML MCP server pro automatický onboarding do KajovoMPCML.

ZÁVAZNÝ VSTUP: Přečti celý příložený Connect in Catalog v1.7. Vytvoř manifest 1.5 a bezpečný ZIP pro Node.js 24/TypeScript. Nevymýšlej KCML identitu; získáš ji až z POST <https://register.hcace.cz/v1/service-onboardings>.

AUTORIZACE: Použij integrační token jako Bearer programátorského API. Plnou hodnotu lze nezamaskovaně psát a zobrazovat v autentizovaném UI, create response, handoffu a správcovské dokumentaci; aplikace do DB a auditu ukládá jen digest a fingerprint. První upload má stabilní Idempotency-Key; opravená revize má nový klíč a aktuální If-Match.

IMPLEMENTACE: Exportuj async invoke, dodej striktní input/output schema, safeInput/expectedResult, testy a přesný lockfile. Nevytvářej veřejný port, vlastní OAuth, Dockerfile, lifecycle skript ani síťový fallback. Upstream použij jen přes context.egress.fetch a manifestový allowlist.

OVĚŘENÍ: Polluj tentýž job. Za dokončené považuj pouze ACTIVE a úplné gates PASS na přidělené HTTPS adrese. Při programmerAction=UPLOAD_REVISION oprav blockingError a neúspěšné gates a nahraj novou revizi. Dokončeno je pouze COMPLETE / ACTIVE; pouze STOP / QUARANTINED předej správci s job ID a correlation ID.

MUST-GEN-03

Samotná odpověď generátoru typu 'hotovo' není akceptační důkaz. Přijímá se pouze změna kódu doprovázená balíčkem C-01 až C-10 a úspěšnými testy T-01 až T-25.

25.1 Doprovodná data k příloze

Pole	Povinná hodnota
FUNCTION_SPEC	Účel jediného nástroje, jeho vstup, výstup, omezení, vedlejší účinky a příklady.
ASSIGNED_KCML_CODE	Kód přidělený katalogem, nebo výslovná hodnota UNASSIGNED.
ASSIGNED_HOSTNAME	Hostname přidělený katalogem, nebo UNASSIGNED; generátor jej nesmí odvodit z příkladu.
ASSIGNED_RESOURCE	Přesná hodnota <a href="https://<assigned-hostname>/mcp">https://<assigned-hostname>/mcp , nebo UNASSIGNED.
TARGET_REPOSITORY	Přesná pracovní kopie/commit, vůči kterému se provede analýza a změna.
UPSTREAM_AND_DATA_CLASS	Závislosti, timeout, klasifikace dat, redakce a pravidla práce s tajemstvími.
APPROVER	Osoba nebo workflow oprávněné schválit kontrakt, bezpečnost, testy a aktivaci.

26. Zajištění shody a finální akceptace

Statický dokument nedokáže sám zabránit chybné implementaci. Požadovaná míra jistoty vzniká teprve kombinací normativního zadání, automatických kontrol a fail-closed provozních bran. Následující mechanismy proto musí být součástí centrálního systému, nikoli pouze slibem vývojáře.

- CI a ochrana větve odmítnou merge, pokud neprojde pnpm run ci, T-01 až T-25 nebo kontrola úplnosti C-01 až C-10.
- Katalogový stavový automat nepovolí TRIAL_TESTING ani ACTIVE bez platných schémat, required CI checks, podepsaného artefaktu, dostupného izolovaného workeru a úspěšného veřejného testovacího běhu.
- enabled=true smí automaticky nastavit pouze onboardingový stavový automat po PASS DNS/TLS/routing, podpisu, autorizace, MCP kontraktu, izolace, loggingu, auditu a monitoringu.
- Runtime vždy odvozuje přesný host z katalogu a při neshodě nebo neplatném autorizačním stavu končí fail-closed před invoke.
- Akceptační důkazy jsou neměnně uloženy s buildId, handlerVersion, registrationRevision a digesty. Změna kteréhokoli z nich zneplatní předchozí schválení.
- Po nasazení proběhne smoke test, kontrola auditních událostí a metrik; rozpor aktivuje QUARANTINED nebo automatické vypnutí podle centrální politiky.
- Pravidelné regresní testy opakují minimálně revokaci, redakci tajemství, integritu schémat a HTTPS preflight.
- Nová verze tohoto standardu nebo centrální protokolové verze vyvolá řízenou revalidaci všech dotčených KCML serverů; jednotlivý handler si výjimku nesmí vyhlásit sám.

ACCEPT-01	Nový KCML MCP server smí být označen jako shodný pouze tehdy, když jsou konkrétní verze tohoto dokumentu, buildId, katalogový manifest, handlerVersion, registrationRevision, digesty, testovací report a schválení navzájem jednoznačně svázány a všechny povinné stavy jsou PASS.
Release gate	Příloha je závazným návodem, nikoli automatickou zárukou. Zárukou přijetí je pouze vynucení kapitoly 26 centrálním CI, katalogovým workflow a runtime kontrolami. Bez tohoto vynucení server zůstává REGISTERED_DISABLED nebo BLOCKED.

27. Automatický onboarding integračním tokenem

Tato kapitola je závazná pro jedinou podporovanou registraci bez ručního vyplňování v UI. Implementační token neobchází bezpečnostní brány: autorizuje jeden serverový onboardingový job, který po úplném PASS sám zaregistruje, otestuje a aktivuje právě jeden nový MCP server.

MUST-AUTO-01

Bez platného integračního tokenu nesmí být programátorské API dostupné. Chybějící, neplatný, expirovaný, revokovaný nebo k jinému jobu použitý token vždy vrací 401 invalid_integration_token.

27.1 Vystavení a správa tokenu v UI

1. Na obrazovce Monitoring MCP zvolit Automaticky integrovat MCP server, nebo otevřít sekci Implementační tokeny a zvolit Vygenerovat token.
2. Zadat label a povinný strukturovaný descriptor budoucího serveru: summary, businessPurpose, serviceOwner, technicalOwner a criticality. Systém vytvoří 512bitovou náhodnou hodnotu s prefixem kci_ ; její plná hodnota se smí nezamaskovaně psát, kopírovat a opakovaně zobrazovat v autentizovaném UI, create response a handoffu. Databáze uloží pouze HMAC digest, key ID a fingerprint.
3. Programátorovi předat tento Connect in Catalog v1.7 a token bezpečným kanálem. Od prvního uploadu programátor sám obsluhuje stav jobu, diagnostiku a opravné revize; správce nemusí ručně vyplňovat registraci, přidělovat HTTPS adresu ani potvrzovat aktivaci. Plnou hodnotu integračního tokenu lze uvést v autentizovaném UI, create response, handoffu a správcovských pracovních poznámkách. Aplikace ji sama nepersistuje ani automaticky nevkládá do auditu nebo provozního logu.
4. Sekce Implementační tokeny zobrazuje expiraci, job, KCML kód, PR/CI/deploy/testy a výslednou HTTPS adresu pouze pro dohled. U opravitelné chyby jedná programátor přes programátorské API; zásah správce není součástí běžného toku. Token nelze editovat; lze jej revokovat nebo skrýt s ponecháním auditu.

Vlastnost	Závazné chování
Entropie a formát	64 CSPRNG bajtů = 512 bitů; kci_<Base64URL>; plná hodnota se smí opakovaně zobrazit v autentizovaném UI a handoffu.
Počáteční TTL	2 hodiny od vystavení pro první upload. Klientské polling ani upload samy expiraci neprodlužují.
Serverové prodlužování	Po navázání prvního uploadu aktivní serverový job nejvýše jednou za 15 minut posune expiraci na now + 2h, nejdéle do issuedAt + 24h. To zahrnuje čekání na opravitelnou revizi, takže programátor může bez správce dovést běžný opravný cyklus do zeleného výsledku.
Vazba	Jeden token -> jeden onboarding job -> jeden KCML kód -> jeden MCP server. Druhá registrace je odmítnuta.
Po ACTIVE	Do aktuální expirace je povolen pouze read-only GET stavu téhož jobu; nový upload, druhý server a změna identity jsou zakázány.
Resume	Běžný samoobslužný tok musí skončit do 24hodinového bezpečnostního stropu. Teprve po jeho překročení zůstane server disabled a worker se zastaví; navazující token ke stejné identitě je mimořádná správcovská obnova, nikoli součást standardního opravného cyklu.

27.2 Rozdíl mezi revokací, zrušením a smazáním

- Revokovat token: programátorské API jej okamžitě odmítne; token nelze obnovit ani změnit.
- Zrušit job: job přejde do CANCELLED, testovací a access tokeny se revokují, server se vypne, worker a egress capability se zastaví.
- Smazat záznam tokenu: provede soft delete a revokaci; neměnný audit, job events a bezpečnostní důkazy zůstanou zachovány.
- Automatický úklid: expirované nebo revokované tokenové záznamy lze po 30 dnech skrýt; auditní události se nemažou.

28. Programátorské API na register.hcasc.cz

Veřejné onboardingové API je oddělené od admin UI, OAuth autority a jednotlivých KCML hostů. Všechny odpovědi obsahují correlationId při chybě a stavové odpovědi používají Cache-Control: no-store.

28.1 První upload a rezervace identity

```
export KCML_INTEGRATION_TOKEN='kci_...'
export IDEMPOTENCY_KEY='company-project-20260713-0001'

curl --fail-with-body --request POST \
  --url https://register.hcasc.cz/v1/service-onboardings \
  --header 'Authorization: Bearer ${KCML_INTEGRATION_TOKEN}' \
  --header 'Idempotency-Key: ${IDEMPOTENCY_KEY}' \
  --form-string 'manifest=$(cat onboarding-manifest.json)' \
  --form 'source=@handler.zip;type=application/zip'
```

Úspěch vrací HTTP 202, ETag s lockVersion a tělo:

```
{
  'job': {
    'id': '•uuid•', 'state': 'SOURCE_UPLOADED', 'lockVersion': 0,
    'code': 'KCML0042', 'hostname': 'kcml0042.hcasc.cz',
    'resource': 'https://kcml0042.hcasc.cz/mcp',
    'toolName': 'kcml0042_example_handler',
    'programmerAction': {'kind': 'WAIT', 'canUploadRevision': false,
    'message': 'Poll this job until it becomes ACTIVE or requests a new revision.'}
  }
}
```

IDEMPOTENCE

Opakování stejného POST se stejným tokenem, Idempotency-Key a stejnými digesty vrátí tentýž job. Stejný klíč s jiným obsahem nebo jiný klíč použitý jako druhá registrace je konflikt, nikoli nový server.

28.2 Polling, opravená revize a zrušení

```
# Stav, gates, PR/CI odkazy a finální HTTPS výsledek
curl --fail-with-body \
  --header 'Authorization: Bearer ${KCML_INTEGRATION_TOKEN}' \
  https://register.hcasc.cz/v1/service-onboardings/${JOB_ID}

# Opravený zdroj pouze ve stavu AWAITING_REVISION nebo FAILED
curl --fail-with-body --request PUT \
  --url https://register.hcasc.cz/v1/service-onboardings/${JOB_ID}/revision \
  --header 'Authorization: Bearer ${KCML_INTEGRATION_TOKEN}' \
  --header 'Idempotency-Key: ${NEW_IDEMPOTENCY_KEY}' \
  --header 'If-Match: '•lockVersion•' ' \
  --form-string 'manifest=$(cat onboarding-manifest.json)' \
  --form 'source=@handler-fixed.zip;type=application/zip'

# Zrušení téhož jobu
curl --fail-with-body --request POST \
  --header 'Authorization: Bearer ${KCML_INTEGRATION_TOKEN}' \
  https://register.hcasc.cz/v1/service-onboardings/${JOB_ID}/cancel
```

Programátor polluje GET téhož jobu. Odpověď vždy obsahuje stav, programmerAction, lockVersion, blokující chybu, jednotlivé gates, correlation ID a bezpečné odkazy na PR/CI. Akce WAIT znamená pokračovat v polling; COMPLETE znamená, že server je ACTIVE.

HTTP	Kód	Význam / postup
400	invalid_manifest / invalid_*	Opravit manifest, ZIP, idempotency key nebo If-Match. Identita se nerecykluje.
401	invalid_integration_token	Token chybí, je chybný, expirovaný, revokovaný nebo nepatří jobu. Opravit předání hlavičky; expirovaný nebo revokovaný token nelze obejít.
409	integration_token_already_bound	Token už založil jiný obsah/job nebo operace není v aktuálním stavu povolena.
412	lock_version_conflict	Znovu načíst GET, převzít aktuální ETag/lockVersion a rozhodnout, zda má být odeslána nová revize.
400	archive_too_large	Zmenšit balík pod 10 MiB; po rozbalení musí zůstat pod 50 MiB.
202	accepted	Job byl přijat nebo byla idempotentně potvrzena stejná revize; pokračovat GET pollingem.

Akce UPLOAD_REVISION znamená opravit blockingError a neúspěšné gates, načíst aktuální ETag/lockVersion a odeslat PUT nové revize se stejným tokenem a jobem, novým Idempotency-Key a If-Match. Identita KCML ani HTTPS adresa se při opravě nemění.

Cyklus GET -> oprava -> PUT -> GET se opakuje bez součinnosti správce až do COMPLETE / ACTIVE. STOP se používá pouze pro CANCELLED nebo neobejitelnou bezpečnostní karanténu; QUARANTINED nesmí programátor sám obnovit ani obejít.

29. Manifest 1.5 a zdrojový balík

29.1 Minimální závazná struktura

NORMATIVNÍ STROJOVÝ VZOR

Úplný validní manifest je docs/onboarding-manifest-v1.5.example.json.
Intake přijímá právě tyto top-level klíče:

schemaVersion, registrationRevision, environment, handlerKey, handlerVersion, displayName, businessPurpose, owners, contacts, criticality, review, source, runtime, tool, contractDigests, behavior, testContract, protocol, dependencies, dataGovernance, monitoringProfile, maintenance, autoQuarantine, errorCatalog, evidence, approvals, change.

Jakékoli další pole nebo chybějící povinná větev je invalid_manifest.

STRICT

Manifest je striktní: neznámá pole, jiné runtime, automatický retry, neplatné JSON Schema nebo hodnoty mimo limity jsou odmítnuty. KCML kód, hostname, resource a finální toolName jsou výstup systému a do manifestu se nekládají.

29.2 Povinný obsah ZIP

```

handler.zip
├── package.json
├── pnpm-lock.yaml
├── tsconfig.json
├── src/
│   ├── index.ts
│   └── index.test.ts

```

- Node.js 24, TypeScript strict, ESM. src/index.ts exportuje async function invoke(input, context).
- Maximálně 10 MiB komprimované, 50 MiB po rozbalení a 1 000 položek; cesty jsou relativní a jedinečné.
- Zakázány jsou symlinky, .., absolutní cesty, .env, .npmrc, .github, node_modules, Dockerfile, binární/native addony, lifecycle skripty a zakódovaná tajemství.
- Závislosti musí být v platformním allowlistu a mít přesné verze. git:, file:, workspace:, rozsahy a postinstall nejsou povoleny.
- tsconfig nesmí dědit cizí konfiguraci, používat plugins/paths/baseUrl ani zapisovat mimo dist; hlavní build ignoruje uploadované skripty.

29.3 Handler a řízení egress

```
type HandlerContext = Readonly •{
  correlationId: string; serverCode: string; toolName: string;
  logger: { info(fields: object, message?: string): void; error(fields: object, message?: string): void };
  egress: { fetch(url: string, init?: object): Promise •{ ok: boolean; json(): Promise •unknown• }• };
}•;

export async function invoke(input: unknown, context: HandlerContext) {
  context.logger.info({ operation: 'example' }, 'handler.started');
  // Jen pokud je host uveden v runtime.egressAllowlist:
  const response = await context.egress.fetch('https://api.example.com/v1', { method: 'GET' });
  if (!response.ok) throw new Error('upstream_failed');
  return await response.json();
}
```

Handler nedostává databázové, session, HMAC, GitHub, administrační, Kaja ani access-token tajemství. Nemá veřejný port a síť je deny-all. context.egress.fetch komunikuje přes privátní Unix socket s centrálním proxy, které znovu ověří capability, přesný HTTPS host/port a veřejné DNS adresy; blokuje loopback, privátní/link-local/metadata rozsahy, DNS rebinding a automatické redirecty.

30. PR, CI, podpis a izolované nasazení

1. API ověří manifest a ZIP, provede bezpečné rozbalení, secret scan a digest a uloží balík do karantény. Webový proces uploadovaný kód nikdy nespustí.
2. Onboarding worker s provozovatelem nakonfigurovanou GitHub API autorizací vytvoří branch integration/kcmlNNNN/<job-id>, zapíše pouze handlers/KCMLNNNN/ a otevře PR. Workflow, root konfigurace, auth a platformní bezpečnostní soubory nesmí PR změnit. Autorizace má přístup pouze k potřebným operacím repozitáře a ke čtení Actions, aby svázala úspěšný trusted main run ID s provenance.
3. PR CI na GitHub-hosted runneru bez produkčních tajemství a bez uložených checkout credentials provede path policy, manifest/schema, lint, typecheck, unit/contract testy, secret scan, SAST, SCA/licence, SBOM a reprodukovatelný build.
4. Po PASS se PR automaticky sloučí. Důvěryhodný main workflow použije pevný Dockerfile, ignoruje lifecycle skripty, sestaví OCI image, vytvoří SBOM a provenance, podepíše image a publikuje jej do GHCR.
5. Worker ověří přesný source commit, build ID, image digest, podpis, SBOM a provenance. Neshoda digestu, podpisu nebo source commit je QUARANTINED bez automatického návratu.
6. Podepsaný handler se spustí v samostatném rootless Podman workeru: non-root, read-only, cap-drop ALL, no-new-privileges, omezené CPU/RAM/PID/concurrency, log-driver none, privátní Unix socket a network none. Pevný supervisor spouští každý call v odděleném podprocesu a po registrovaném timeoutu jej ukončí, takže zablokovaný handler nemůže pokračovat na pozadí.

Stav jobu	Význam
CREATED / SOURCE_UPLOADED	Token byl vystaven; poté je validovaný balík navázán na jedinou rezervovanou KCML identitu.
PR_CREATED / CI_RUNNING	PR existuje a required checks se ukládají jako persistentní gates.
AWAITING_REVISION	Opravitelná CI chyba; povolen je PUT nové revize se stejným tokenem/jobem a If-Match.
MERGED / ARTIFACT_BUILDING	Zdroj je na main; čeká se na podepsaný immutable OCI artefakt.
DEPLOYING / REGISTERED_DISABLED	Worker běží izolovaně; katalog, monitoring, statistiky, audit a digesty existují, ale veřejná funkce je disabled.
TRIAL_TESTING	Dočasně enabled pouze pro systémové Kaja pověření a reálné veřejné testy.
ACTIVE	Všechny gates PASS; server zůstává enabled a monitoring může vyhodnotit HEALTHY.
FAILED / QUARANTINED / CANCELLED	Server je vypnut. FAILED s programmerAction=UPLOAD_REVISION dovolí opravený zdroj stejného jobu; QUARANTINED je neobejitelná bezpečnostní stopka a CANCELLED je konečný stav.

31. Vlastní HTTPS adresa a automatická aktivace

Každý token rezervuje vlastní identitu KCMLNNNN a vlastní resource <https://kcmlNNNN.hcasc.cz/mcp>. Wildcard DNS samo nestačí: produkce musí mít DNS-01 certifikát pro *.hcasc.cz, regex routing jen pro kcml[0-9]{4}.hcasc.cz, zachovaný Host a defaultní odmítnutí jiných hostů.

Gate	Povinný PASS
Preflight	DNS, TLS řetězec a SAN konkrétního hostname, SNI, Host routing, protected-resource metadata, image signature, runtime socket a worker readiness.
OAuth	Systémové Kaja pověření jen pro testovaný server, client_credentials; chybějící a neplatný token jsou odmítnuty.
MCP	initialize, notifications/initialized, tools/list s jediným toolName, bezpečný tools/call, input/output schema, timeout a velikostní limity.
Observabilita	Stejně correlation ID v gateway, auditu a runtime logu; persistentní statistiky/probes; redakce a nepřítomnost integračního, Kaja, access a egress tokenů.
Monitoring	Readiness, DNS/TLS metadata, syntetický call a artifact integrity. HEALTHY vznikne jen při úplném PASS.

AUTO-ACTIVE	Po úplném PASS přepne job bez závěrečného kliknutí server na ACTIVE/enabled=true. Automatika nikdy neznámá bypass. Jakýkoli kritický bezpečnostní nebo integritní problém server vypne; digest drift, neplatný podpis nebo únik tajemství vždy znamená QUARANTINED.
-------------	---

32. Finální checklist programátora

- ☐ Plná hodnota integračního tokenu byla podle potřeby uvedena v handoffu nebo správcovské dokumentaci; databáze a automatický audit/log obsahují pouze digest a fingerprint.
- ☐ Manifest 1.5 je striktní, JSON Schema se kompilují a safeInput/expectedResult lze bezpečně opakovat.
- ☐ ZIP obsahuje jen schválené kořenové soubory a TypeScript pod src/, přesný lockfile, tsconfig, src/index.ts a automatické testy.
- ☐ První POST má stabilní Idempotency-Key; každá opravená revize má nový klíč a aktuální If-Match.
- ☐ Polling skončil stavem ACTIVE a všechny gates jsou PASS; výsledný resource odpovídá přidělenému hostname.
- ☐ Při UPLOAD_REVISION programátor opravil blockingError a neúspěšné gates a opakoval PUT/GET až do ACTIVE. Pouze STOP / QUARANTINED předá správci s job ID a correlation ID.
- ☐ Po ACTIVE byl token použit už jen pro GET stavu a poté bezpečně zničen.

ACCEPT-AUTO	Automatický onboarding je přijat pouze s jedním jobem, jedním KCML serverem, podepsaným immutable image digestem, vlastní platnou HTTPS adresou, úplnými gates PASS a finálním stavem ACTIVE/HEALTHY. Jiný výsledek není dokončená integrace.
-------------	---

33. Registrační kontrakt manifestu 1.5

Každý nový onboarding a každá změnová revize používá výhradně striktní manifest 1.5. Produkční revize 1.4 zůstává čitelná do příští změny nebo recertifikace; nesmí být přepsána ani automaticky doplněna bezpečnostními defaulty. Úplný validní strojový vzor je soubor docs/onboarding-manifest-v1.5.example.json v téže repozitáři.

STRICT-1.5

Neznámé pole, chybějící evidence reference, neplatný digest, nesoulad anotací, egress politiky, error katalogu nebo review intervalu odmítne intake před rezervací KCML identity.

Skupina	Povinný přesný obsah
Identita revize	schemaVersion=1.5, registrationRevision, environment, handlerKey, handlerVersion, displayName a businessPurpose. KCML kód, hostname, resource a finální toolName jsou výstup systému.
Odpovědnost	owners.service/technical/security/operations, contacts.serviceEmail/technicalEmail/securityEmail/operationsOnCall a criticality.
Recertifikace	review.intervalDays, approvedAt a reviewDueAt. Due date musí přesně odpovídat intervalu; citlivé, kritické a non-idempotentní služby nejvýše 180 dní, ostatní nejvýše 365 dní.
Kontrakt	tool, strict Draft 2020-12 inputSchema/outputSchema, annotations, contractDigests, behavior, protocol a shodný errorCatalog.
Testy	safeInput, expectedResult, positiveEvidenceRef, nejméně jeden negative test, dependency failure scenario, 30-240min load profile a rollback důkaz.
Závislosti	Přesné runtime verze/checksumy, HTTPS externalServices, secretReferences s vlastníkem a rotací a fail-closed networkPolicy.
Data	classification, personal-data příznak, residencyCountries, exportAllowed/destinations, logging/redaction policy, retentionDays a evidenceRef.
Monitoring	SLO, všech sedm probe intervalů, staleAfterSeconds nejméně jako nejdelší interval, alertRules, runbook a oba podepsané webhook kanály.
Governance	maintenance, všech pět autoQuarantine pravidel, scan/SBOM/provenance evidence, compatibility window, pět schválení a change vazby.

33.1 Descriptor integračního toku

POST /api/integration-tokens přijímá pouze label, descriptor a volitelné resumeJobId. Descriptor není poznámka; je povinnou budoucí identitou vazby a striktně obsahuje summary, businessPurpose, serviceOwner, technicalOwner a criticality. Legacy note ani hodnota unspecified nejsou přijatelné.

TOKEN-VALUE

Plná hodnota integračního tokenu se smí nezamaskovaně psát, kopírovat a opakovaně zobrazovat v autentizovaném UI, create response, handoffu a správcovských pracovních poznámkách. Databáze a automatický audit/log ukládají pouze HMAC digest a fingerprint; runtime hodnotu sám do logu nevkládá.

34. Stavový automat a recertifikace

registration_state mění výhradně centrální doménová služba. Aktivace vždy prochází REGISTERED_DISABLED -> TRIAL -> ACTIVE. Přímá změna aktivního monitorovacího profilu je zakázána a vytvoří novou registrační revizi. Návrat z QUARANTINED vyžaduje novou revizi, opakované testy a ruční schválení.

Fáze	Časové pravidlo a vynucení
VALID	Více než 30 dní do reviewDueAt. Běžný provoz, vydání tokenu, discovery a monitorování jsou povoleny při splnění všech ostatních gates.
WARNING	Od přesného okamžiku 30 dní před reviewDueAt. Jednorázový Warning, odpočet v UI, audit a oba podepsané webhooks.
GRACE	Od reviewDueAt do přesného okamžiku +30 dní. Stávající provoz pokračuje, ale nová aktivace nebo změnová revize je blokována.
SUSPENDED	Od +30 dní včetně. Server se vypne, zvýší revocation epoch, revokují se tokeny a discovery i MCP volání selžou fail-closed.
INVALID	Chybějící, neplatná nebo nedohledatelná aktivní revize/profil znamená okamžitou jednotnou nedostupnost a auditovaný důvod.

- Stejný recertifikační evaluátor se používá při aktivaci, zapnutí, testu, vydání i validaci Bearer tokenu, discovery a monitoringu.
- SUSPENDED, QUARANTINED, RETIRED a neplatná registrace nezveřejní katalogové detaily ani metadata známého serveru.
- Chybějící aktivní revision nebo monitoring profile nikdy nepřejde přes infinity, cache, implicitní enabled ani jinou fail-open větev.

35. Forenzní audit, invocation a centrální monitor

Oblast	Nevyjednatelný provozní kontrakt
Audit chain	Hash eventu vytváří databázová funkce a trigger pod serializovaným audit_head. Aplikace nedodává previous hash a nemůže historickou událost měnit ani mazat.
Historie	Migrace v jedné kontrolované transakci přepočte historické události, ověří celý řetězec a teprve potom obnoví append-only ochranu.
Invocation intent	Před handlerem vznikne accepted invocation a audit intent. Selhání pre-auditů zabrání spuštění handleru.
Invocation outcome	Výsledek, statistiky a konečný audit se dokončí transakčně. Selhání po vedlejším účinku vrátí chybu, vytvoří Critical alert a handler se automaticky neopakuje.
Monitor isolation	Samostatná kcml-monitor.service zpracuje každý server izolovaně. Jedna chyba nezastaví jiné probes ani onboarding worker; vznikne monitoring.internal_error s correlationId a backoffem.
Probe set	Liveness, readiness, TLS expirace, routing, OAuth/MCP, synthetic call, artifact/contract/profile drift, dependencies, staleness a SLO mají vlastní plán a historii.
Alert delivery	Primary i backup HTTPS webhook používají samostatný HMAC podpis. Delivery má idempotency ID, pokusy, odpověď, next retry a dead-letter stav.

FAIL-CLOSED

Nedostupná databáze, audit writer, aktivní revize, monitorovací profil, autorizace, handler, podepsaný artefakt nebo deklarovaná povinná závislost nesmí spustit handler ani zpřístupnit náhradní server.

36. Produkční release a akceptace

1. CI sestaví jeden immutable release artifact s produkčními dependencies, SBOM, checksumem a GitHub OIDC attestation; produkce zdroj nekompile ani nestahuje balíčky.
2. OCI handler se podepíše keyless Cosign přes GitHub OIDC a produkce ověří issuer, repository a workflow identity.

3. Produkční environment vyžaduje ruční schválení a main; jediný ručně spravovaný GitHub secret je PASS. Automatický GITHUB_TOKEN není uživatelský secret.
4. Deployment ověří attestation, zašifruje a zkontroluje zálohu, aplikuje pouze dopředné migrace, synchronizuje heslo deploymentem zvoleného OWNER účtu, atomicky přepne release a spustí smoke test.
5. Web, onboarding, monitor a egress používají oddělené systemd credentials a nejmenší nutná oprávnění. Aplikační role nevlastní auditní tabulku ani migrace.
6. Go/no-go ověří login, auth metadata, neznámý host, KCML0002, recertifikaci, audit chain, monitor, oba webhooky, rollback a aktivní služby.

Akceptační důkaz	Povinný výsledek
Migrace	Čistá DB i upgrade kopie produkčního schématu; kanonický ledger 001-033, SHA-256 shoda, žádná opožděná ani změněná migrace.
Audit	100 souběžných zápisů bez větvení, tamper detection a verify_audit_chain valid=true po backfillu.
Runtime	Cizí audience, chybějící revize/profil, suspend, quarantine a unknown host jsou odmítnuty před invoke.
Monitoring	Vadný manifest jednoho serveru nezastaví ostatní probe ani onboarding; alert delivery a dead-letter jsou dohledatelné.
UI	Token modal s deskriptorem a plnou hodnotou, permissions, recertifikační odpočet, monitor, alerty, webhooky, historie a prázdné stavy projdou Testing Library interakčními testy, axe kontrolou dialogů a renderovaným desktop/mobile auditem.
Produkce	PASS je jediný uživatelský GitHub secret, backup/restore důkaz je platný, služby active a KCML0002 zůstává ACTIVE/HEALTHY.

ACCEPT-1.7

Integrace je dokončena pouze tehdy, když je manifest 1.5 neměnný a dohledatelný, runtime rozhodnutí odpovídá aktuální autorizaci a recertifikaci, auditní řetězec je validní, monitoring není zastaralý a produkční důkazy jsou PASS.